Livre 5 : Topologie de sécurité et configuration de résilience du clearing

Titre	Livre 5 : Topologie de sécurité et configuration de résilience du clearing
Auteur ·	M. Denis Bouzon
ORCID	0009-0007-8894-8902
Version / date	2.1 ; 17 octobre 2026
Page de présentation	www.osnias-clearing.com/security
Licence	© 2026 Denis Bouzon — All rights reserved
URL DOI	

Prior Osnias documentation

Book 1	Osnias ID	https://www.osnias-clearing.com/osniasid/
Book 2	Architecture	https://www.osnias-clearing.com/architecture/
Book 3	Règles	https://www.osnias-clearing.com/rules/
Book 4	Cycles / Calendrier	https://www.osnias-clearing.com/cycles/
Book 5	Sécurity	https://www.osnias-clearing.com/security/
Book 6	Onboarding	https://www.osnias-clearing.com/onboarding/
Book 7	O-POP	https://www.osnias-clearing.com/pop/

Résumé

Ce document présente l'architecture de sécurité des utilisateurs finaux d'Osnias Clearing sur l'ensemble du cycle de vie de leur identité : entrée dans le dispositif, autorisation dans deux domaines indépendants, libération sécurisée des fonds, renouvellement cryptographique et sortie du dispositif. Il précise également les rôles administratifs du gestionnaire de nœud et du gestionnaire Osnias, leurs clés dédiées et les contrôles de netting et de plafonnement du séquestre. Son objectif est de réduire le risque qu'une compromission d'une seule clé opérationnelle ECDSA entraîne le détournement des fonds sous séquestre.

L'architecture utilise les chaînes existantes sans les modifier. Elle sépare l'adresse EVM de signature opérationnelle, un domaine d'autorisation Sei indépendant et une adresse EVM froide de réception, issue d'une troisième graine et préalablement enregistrée dans le contrat intelligent. Cette adresse n'a pas vocation à signer pendant sa phase de réception : elle constitue un bénéficiaire prédéfini, et non une clé d'autorisation opérationnelle. La compromission du signataire opérationnel ne confère donc pas, à elle seule, le contrôle de la destination des fonds libérés.

Le risque d'une future attaque contre des clés publiques ECDSA exposées est traité comme un risque cryptographique prospectif, et non comme une menace opérationnelle actuelle avérée. La démarche relève de

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

la sécurité à long terme : les mécanismes disponibles sur les chaînes actuelles réduisent une catégorie plausible de risques sans prétendre qu'ECDSA est devenu résistant aux attaques quantiques. Statut du document : évaluation technique interne et préparation à l'audit. Les contrôles sont classés selon les preuves disponibles ; ce document ne constitue ni un audit indépendant, ni une vérification formelle, ni un rapport de test d'intrusion, ni une certification de sécurité en production.

Mots-clés

Osnias-ID ; entrée dans le dispositif ; sortie du dispositif ; ECDSA ; secp256k1 ; séquestre EVM ; risque quantique ; adresse froide de réception ; autorisation dans deux domaines ; défense en profondeur ; hygiène cryptographique ; attaque fondée sur l'algorithme de Shor.

Table des matières

1 Statut de l'évaluation et niveau documentaire....3
2 Périmètre, méthode et référentiels de l'évaluation....3
  2.1 Référentiels méthodologiques....4
3 Matrice d'évaluation des contrôles....4
4 Objet, principes de sécurité et périmètre....5
  4.1 Perspective de sécurité à long terme....5
  4.2 Propriétés recherchées....5
  4.3 Propriétés non revendiquées....6
5 Cycle de vie de la sécurité de l'utilisateur....6
6 Architecture de l'entrée sécurisée....6
  6.1 Domaine A — Signataire EVM opérationnel....6
  6.2 Domaine B — Autorisation Sei indépendante....6
  6.3 Domaine C — Adresse froide de réception indépendante....6
  6.4 Indépendance des graines et risque de cascade BIP-32....7
  6.5 Condition composite de libération....8
  6.6 Règle du bénéficiaire prédéfini....8
  6.7 Ensemble minimal des données liées à l'autorisation....8
  6.8 Autorisation à usage unique et protection contre le rejeu....8
  6.9 Cycle de vie du portefeuille de réception....8
7 Modèle de menace à long terme : compromission d'une clé et risque lié à Shor....8
  7.1 Scénario prospectif lié à Shor....8
  7.2 Objectif de l'attaquant....9
  7.3 Pourquoi la clé récupérée reste insuffisante....9
  7.4 Surface d'attaque résiduelle....9
8 Osnias-ID, intégrité des registres et protection contre le rejeu....9
  8.1 Cohérence des registres et risque TOCTOU....9
  8.2 Séparation du plan de contrôle....9
9 WW=00 : mode de sécurité du séquestre autonome....9
10 Hygiène cryptographique, renouvellement de l'identité et sortie....10
  10.1 Renouvellement complet....10
  10.2 Sortie et révocation définitive....11
11 Exigences de renforcement institutionnel....11
12 Limites et travaux ouverts....12
13 Feuille de route de l'implémentation et de la validation de sécurité....12
14 Conclusion....13
15 Bibliographie....13

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

Statut de l’évaluation et niveau documentaire

Ce document constitue une évaluation technique interne et une préparation à l’audit du dispositif de sécurité envisagé pour les utilisateurs finaux d’Osnias Clearing. Il examine l’architecture, les frontières de confiance, les objectifs de contrôle, les risques ouverts et les preuves nécessaires à une validation ultérieure de l’implémentation. Il ne constitue ni un audit indépendant, ni une vérification formelle, ni un test d’intrusion, ni un audit de conservation des actifs, ni un avis juridique, une certification ou une autorisation de mise en production.

Élément évalué	Statut actuel
Niveau documentaire	Évaluation technique interne et préparation à l’audit de sécurité
Fondement de la revue	Architecture de sécurité des utilisateurs finaux d’Osnias Clearing — Version 4.3
Évaluateur	Denis Bouzon / Osnias Clearing — évaluation interne
Preuves d’implémentation	En attente pour les contrôles identifiés dans le document
Campagne adversariale sur testnet	En attente
Audit indépendant par un tiers	Non réalisé
Certification de sécurité en production	Non revendiquée
Statut général	Conception évaluée ; preuves d’implémentation, tests adversariaux et revue indépendante en attente

Terminologie relative aux preuves : EXIGENCE DE CONCEPTION — propriété de sécurité visée ; SPÉCIFIÉ — sémantique du contrôle décrite ; IMPLÉMENTATION EN ATTENTE — preuve au niveau du code indisponible ; TESTS EN ATTENTE — preuve issue de tests adversariaux indisponible ; OUVERT — décision importante de conception ou d’implémentation non résolue ; REVU INDÉPENDAMMENT — réservé aux contrôles examinés ultérieurement par un évaluateur indépendant identifié.

Périmètre, méthode et référentiels de l’évaluation

Périmètre. L’examen couvre le signataire EVM opérationnel, l’autorisation Sei indépendante, le bénéficiaire froid préalablement enregistré, la condition composite de libération, la protection contre les rejeux, la cohérence d’Osnias-ID et des registres, les hypothèses de vérification entre chaînes, le renouvellement et la sortie de l’identité, les pouvoirs administratifs, les clés dédiées du gestionnaire de nœud et du gestionnaire Osnias, l’équilibrage de netting et les plafonds de séquestre par nœud, la conservation des clés par les participants et la validation prévue.

Exclusions. L’examen n’atteste ni le code déployé, ni l’infrastructure de production, ni les fournisseurs de portefeuilles, ni les dispositifs de conservation des participants, ni l’exactitude du consensus de la chaîne source, ni la conformité juridique ou réglementaire, ni l’efficacité de contrôles qui n’ont pas été implémentés et documentés. Bien que le consensus de la chaîne source soit hors périmètre, la libération entre chaînes dépend d’une hypothèse explicitement documentée sur la finalité et l’authentification de l’état source.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

Méthode. Les contrôles sont appréciés par revue d'architecture, analyse des frontières de confiance, des scénarios de compromission, des invariants, du cycle de vie, des pouvoirs administratifs et des défaillances entre chaînes. L'analyse identifie aussi les risques résiduels et les preuves d'implémentation et de tests adversariaux nécessaires avant toute qualification pour la production.

Référentiels méthodologiques

- ISO 19011:2026 — Lignes directrices pour l'audit des systèmes de management : principes d'audit, organisation du programme et approche fondée sur les preuves et les risques.
- ISO/IEC 27001:2022 — Systèmes de management de la sécurité de l'information : gouvernance des risques et contexte de gestion de la sécurité.
- ISO/IEC 27002:2022 — Mesures de sécurité de l'information : recommandations relatives notamment au contrôle d'accès et à la cryptographie.
- ISO/IEC 27005:2022 — Gestion des risques de sécurité de l'information : identification, évaluation et traitement structurés.
- ISO/IEC 27034-1:2011 — Sécurité des applications : intégration des principes et processus de sécurité au cycle de vie des applications.
- NIST SP 800-218, SSDF v1.1 — Cadre de développement logiciel sécurisé : pratiques de développement, réduction des vulnérabilités et production de preuves tout au long du cycle de vie.

Précision sur les référentiels. Ces normes et cadres ne sont cités que comme références méthodologiques et de conception. Leur mention n'implique aucune certification ISO, évaluation de conformité, approbation du NIST, validation indépendante ou affirmation selon laquelle Osnias Clearing aurait été audité sur l'ensemble des exigences citées.

Matrice d'évaluation des contrôles

La matrice distingue les exigences de conception des preuves d'implémentation. La criticité décrit les conséquences possibles de l'absence ou du contournement d'un contrôle ; elle ne signifie pas qu'une vulnérabilité a déjà été observée dans du code déployé. La colonne « Action requise » indique les travaux et preuves nécessaires pour progresser vers la vérification.

ID	Contrôle / constat	Criticité	État actuel des preuves	Action requise
SEC-001	Le signataire opérationnel ne doit pas choisir ou remplacer librement le bénéficiaire de la libération.	Critique	EXIGENCE DE CONCEPTION	Implémenter et tester l'immuabilité ou la modification contrôlée du bénéficiaire dans le contrat ; vérifier que les destinations arbitraires sont rejetées.
SEC-002	L'autorisation de libération doit être à usage unique et liée au nonce, à la preuve et au bénéficiaire prédéfini.	Élevée	SPÉCIFIÉ	Consommer les nonces et preuves ; tester les rejeux et substitutions de contrat, chaîne, montant ou bénéficiaire.
SEC-003	L'authentification de l'état Sei canonique, la finalité et les réorganisations, le quorum et la rotation du vérificateur exigent des preuves d'implémentation.	Élevée	OUVERT	Définir ces mécanismes ; tester les défaillances et les états périmés.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

SEC-004	Aucune autorité unique de mise à niveau, registre, vérification ou urgence ne doit contourner la condition composite ni modifier seule le bénéficiaire.	Critique	EXIGENCE DE CONCEPTION	Définir la séparation des rôles et les contrôles à seuil ; tester les abus des voies administratives et d'urgence.
SEC-005	Les graines A, B et C exigent des racines indépendantes et une isolation des défaillances communes ; les clés restent sous la garde du participant.	Élevée	SPÉCIFIÉ / IMPLÉMENTATION EN ATTENTE	Documenter la génération et la conservation ; prouver l'indépendance des racines et tester les mauvaises configurations à l'entrée.
SEC-006	La migration de l'identité et le lien avec son successeur exigent une machine d'états et des tests adversariaux.	Élevée	IMPLÉMENTATION EN ATTENTE	Implémenter états, associations, conditions de migration et révocation définitive ; tester les attaques de migration.
SEC-007	Analyse statique, scénarios d'attaque sur testnet, corrections et nouveaux tests restent nécessaires avant la revue indépendante.	Élevée	TESTS EN ATTENTE	Exécuter Slither et la campagne adversariale ; corriger, retester et publier le rapport de validation.
SEC-008	La clé dédiée du gestionnaire de nœud ne doit agir que sur son nœud, dans la fenêtre autorisée et selon les positions nettes arrêtées.	Critique	EXIGENCE DE CONCEPTION / IMPLÉMENTATION EN ATTENTE	Tester les opérations hors nœud, hors fenêtre, les montants injustifiés, les destinations non enregistrées et les doubles exécutions ; vérifier le traitement des soldes débiteurs et créditeurs.
SEC-009	La clé du gestionnaire Osnias administre les numéros et paramètres des nœuds sans disposer de leurs actifs ; les plafonds de séquestre doivent être appliqués par les contrats.	Élevée	EXIGENCE DE CONCEPTION / IMPLÉMENTATION EN ATTENTE	Spécifier les unités et le périmètre des plafonds, leur modification et leur réduction ; tester les dépassements et les abus de droits administratifs.
SEC-010	Les graines des gestionnaires doivent être indépendantes entre elles et des domaines A, B et C ; la rotation et la révocation doivent préserver les restrictions de rôle.	Élevée	EXIGENCE DE CONCEPTION / TESTS EN ATTENTE	Documenter la génération, la conservation et la récupération ; tester l'affectation, la révocation, la rotation et la compromission de chaque clé de gestion.
SEC-011	Le participant ne peut ajuster son séquestre que pendant les jours 2 à 4 ; tout retrait doit rejoindre son adresse dédiée enregistrée ; le séquestre est bloqué à la clôture du jeudi.	Critique	EXIGENCE DE CONCEPTION / IMPLÉMENTATION ET TESTS EN ATTENTE	Préciser la borne de clôture UTC ; tester ajouts et retraits aux limites de fenêtre, montants non libérables, substitution de destination, dépassement du plafond et maintien des opérations de règlement autorisées.

Interprétation de la criticité : Critique — l'absence du contrôle pourrait permettre un détournement direct des fonds ou supprimer la séparation des autorisations ; Élevée — faiblesse importante d'un contrôle ou d'une frontière de confiance ; Moyenne — faiblesse à corriger avant la production ; Faible — recommandation de renforcement ; Information — observation sans effet direct démontré sur la sécurité.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

Invariant administratif visé. Aucune autorité unique chargée des mises à niveau, registres, vérificateurs ou mesures d'urgence ne doit pouvoir modifier seule la condition de libération, changer le bénéficiaire enregistré ou désactiver l'autorisation indépendante du second domaine. Les seuils, délais de sûreté et règles de séparation des fonctions restent à implémenter et à documenter avant toute vérification indépendante.

Objet, principes de sécurité et périmètre

Osnias Clearing traite la sécurité des fonds des utilisateurs comme une propriété du cycle de vie, et non comme un simple problème de signature. Le protocole sépare la signature opérationnelle, l'autorisation indépendante, la destination des fonds, l'état du registre et les contrôles du cycle de vie de l'identité. Cette architecture est conçue pour les infrastructures EVM et Sei actuelles tout en réduisant les conséquences d'une éventuelle compromission future de clés classiques exposées.

Principe de conception : réduire les risques futurs avec les chaînes disponibles aujourd' hui.

Perspective de sécurité à long terme

L'algorithme de Shor établit une voie théorique de résolution du problème du logarithme discret sur courbe elliptique avec un ordinateur quantique suffisamment puissant. Ce document n'affirme pas qu'une telle capacité existe actuellement contre les comptes secp256k1 en conditions opérationnelles. Le scénario quantique est donc prospectif. La question technique est plus précise : si un attaquant récupère demain une clé de signature opérationnelle exposée, cette seule clé doit-elle permettre de détourner des fonds séquestrés ?

La réponse d'Osnias relève de l'architecture. Sans modifier ECDSA, elle modifie les conditions de libération des fonds et leur destination autorisée. Cette approche constitue une défense en profondeur, sans prétention de sécurité post-quantique complète.

Propriétés recherchées

- La compromission de la clé de signature EVM opérationnelle ne devrait pas, à elle seule, satisfaire l'ensemble des conditions de libération.
- Un second domaine d'autorisation, généré indépendamment sur Sei, peut ajouter une condition cryptographique indépendante.
- Une adresse EVM froide prédéfinie pour la réception peut dissocier le pouvoir de signer de celui de désigner la destination des fonds.
- **L'architecture peut être mise en œuvre avec des contrats EVM existants, des adresses EOA, l'état des registres, des nonces et un état entre chaînes authentifié.**

Propriétés non revendiquées

- Aucune résistance quantique complète, démonstration formelle ni mesure chiffrée de sécurité post-quantique n'est revendiquée.
- L'adresse froide de réception ne rend pas ECDSA post-quantique ; elle réduit l'utilité de la compromission du signataire opérationnel pour détourner les fonds.
- **Le vérificateur, la gouvernance des registres, le consensus de la chaîne source et le pouvoir de mise à niveau restent des frontières de confiance explicites.**

Cycle de vie de la sécurité de l'utilisateur

Le cycle de vie comprend l'entrée dans le dispositif, l'exploitation active, la libération sécurisée des fonds, le renouvellement facultatif de l'identité et la sortie du dispositif. Osnias fournit les mécanismes et transitions d'état ; le participant conserve la maîtrise de sa politique de sécurité, notamment du choix et du moment de renouveler son identité cryptographique.

- À l'entrée, Osnias-ID est établi et relié au signataire EVM opérationnel, au domaine Sei indépendant et à l'adresse froide de réception.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

- Pendant l’exploitation, le signataire opérationnel effectue les interactions EVM courantes ; le second domaine et le vérificateur limitent le pouvoir de libération.
- Les fonds libérés sont envoyés uniquement au bénéficiaire préalablement enregistré, jamais à une destination arbitraire fournie au moment de la libération.
- Le renouvellement et la sortie créent, si souhaité, une nouvelle identité, déplacent ou règlent les positions restantes, puis révoquent irréversiblement l’ancienne.

Architecture de l’entrée sécurisée

L’entrée dans le dispositif crée l’identité de sécurité du protocole. Osnias-ID sert de lien entre ses éléments ; il ne constitue pas lui-même une clé cryptographique. La sécurité dépend de la séparation des rôles techniques associés à cet identifiant.

Domaine A — Signataire EVM opérationnel

Le domaine A comprend la clé et l’adresse EVM de signature opérationnelle du participant. Profil recommandé : créer et conserver cette clé dans un portefeuille matériel, permettant les signatures EVM courantes sans exposer la clé privée à l’ordinateur généraliste. Cette clé opérationnelle, potentiellement exposée par l’activité habituelle de signature, ne doit pas pouvoir déterminer seule la destination finale des fonds libérés du séquestre.

Domaine B — Autorisation Sei indépendante

Le domaine B provient d’une graine indépendante et participe au processus canonique d’autorisation ou de transition d’état sur Sei. Le participant peut utiliser un portefeuille opérationnel compatible avec Sei, tel que MetaMask si l’environnement retenu le permet. Aucune graine, racine de dérivation ou donnée de récupération ne doit être commune aux domaines A et B. La séparation des réseaux ne suffit pas si la graine sous-jacente est partagée.

Domaine C — Adresse froide de réception indépendante

À l’entrée, un bénéficiaire EVM dédié est également enregistré à partir d’une troisième graine indépendante. Profil recommandé : la graine C reste hors ligne dans un portefeuille froid, normalement inutilisé pour signer les opérations courantes. Son adresse est inscrite comme bénéficiaire de la libération. Durant la phase prévue pour recevoir les fonds, cette adresse n’a pas besoin de signer ; une simple réception ne révèle donc pas sa clé publique au moyen d’une signature ECDSA sortante.

Le bénéficiaire est fixé avant la libération. Le signataire opérationnel ne doit pas pouvoir substituer une destination arbitraire à ce moment. Toute modification devrait relever d’une procédure distincte de renouvellement ou de nouvelle entrée, sous contrôle approprié, plutôt que d’une décision unilatérale du signataire.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

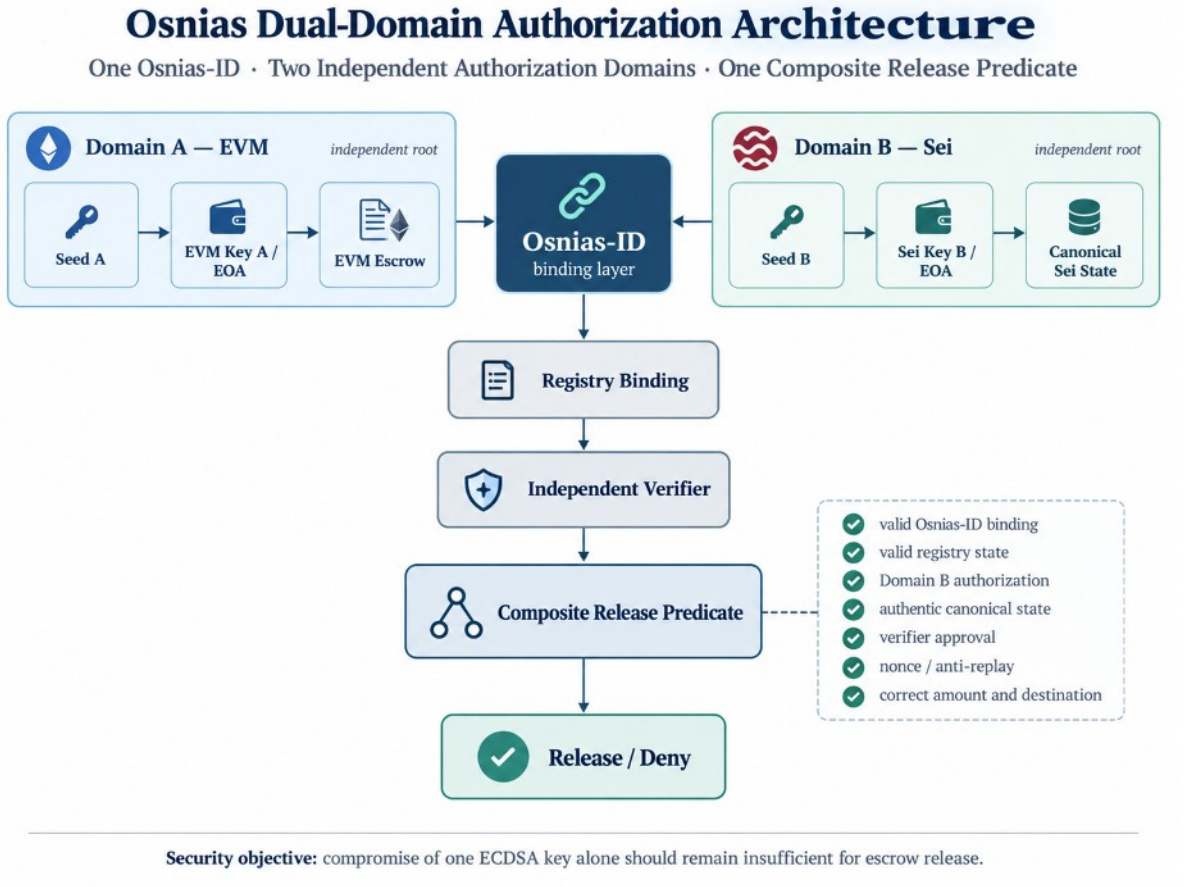


Figure 1 — Architecture d'autorisation à deux domaines

Indépendance des graines et risque de cascade BIP-32

Les graines A, B et C doivent être générées indépendamment : une racine commune compromettrait la séparation recherchée. Plusieurs adresses dérivées d'une même graine ne forment pas des domaines de sécurité indépendants. Dans la mesure du possible, les générations doivent également éviter un même environnement compromis.

Responsabilité de conservation du participant. Les graines A, B et C, clés privées, phrases de récupération, appareils matériels et sauvegardes demeurent sous la garde et la responsabilité opérationnelle du participant. Osnias Clearing ne détient, ne séquestre, ne sauvegarde, ne récupère et ne contrôle aucune clé privée ni phrase de récupération des participants. Ceux-ci restent responsables de la génération, du stockage, de la récupération, des accès et de leur politique de conservation.

Isolation des défaillances communes. Des graines distinctes créées sur un même appareil compromis, dans une même session ou un même environnement de récupération, ou sous un contrôle administratif commun, ne garantissent pas une isolation complète. Les déploiements institutionnels devraient démontrer la séparation par des cérémonies de création de clés, des domaines HSM ou de conservation distincts, ou des procédures équivalentes approuvées.

Risque de signature dans le domaine B. Une autorisation indépendante ne protège pas contre une cosignature malveillante ou une signature aveugle. Le contrôle visé est de lier l'autorisation Sei à une intention lisible par un humain, à Osnias-ID, au bénéficiaire, à l'actif, au montant, au nonce et à l'expiration, afin que le participant puisse vérifier l'opération avant de l'approuver.7. Autorisation composite et libération sécurisée des fonds

La fonction de libération repose sur une condition composite. La signature valide du signataire EVM opérationnel n'est nécessaire que si l'action concernée l'exige ; elle ne suffit pas à rediriger les fonds séquestrés.

Condition composite de libération

Objectif d'audit — condition composite. La conception exige un lien Osnias-ID valide, un état acceptable du registre, une autorisation authentifiée du second domaine ou un état canonique de la chaîne source, l'accord

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

du vérificateur, des garanties de fraîcheur et contre les rejeux, ainsi qu'une concordance exacte avec le bénéficiaire préalablement enregistré. L'application effective par le contrat reste à prouver par l'implémentation et les tests.

Si la condition composite est remplie, les fonds vont au bénéficiaire froid enregistré, jamais à une adresse fournie à la dernière minute par le signataire opérationnel.

Règle du bénéficiaire prédéfini

Exigence de conception — bénéficiaire prédéfini. Le bénéficiaire doit être enregistré lors de l'entrée dans le dispositif ou d'une procédure offrant une protection équivalente. La voie normale de libération ne doit pas permettre au signataire opérationnel de fournir une destination arbitraire. Une preuve d'application au niveau du contrat est nécessaire avant de considérer ce contrôle comme vérifié.

Ensemble minimal des données liées à l'autorisation

Une autorisation en production devrait lier au minimum : version du protocole et séparateur de domaine ; Osnias-ID ; identifiants des chaînes source et destination ; contrat séquestre vérificateur ; identifiant précis de l'actif ; code devise ISO 4217 le cas échéant ; cycle ou mode ; montant ; nonce unique ; référence de l'état canonique source ; identifiant de l'autorisation de libération ; engagement du bénéficiaire ; horodatage ; condition d'expiration ou de fraîcheur.

Autorisation à usage unique et protection contre le rejeu

La preuve doit être utilisable une seule fois. Le séquestre doit enregistrer la consommation du nonce ou de l'identifiant de preuve et rejeter les rejeux ainsi que les substitutions de contrat, de chaîne, de montant et de bénéficiaire.

Cycle de vie du portefeuille de réception

L'adresse froide de réception ne signe pas pendant sa phase de réception prévue ; elle sert de bénéficiaire prédéfini et non de clé d'autorisation opérationnelle. Si le participant déplace ensuite ces fonds, l'adresse entre dans une phase active de signature. Il peut, à titre facultatif, désigner une nouvelle adresse froide pour les libérations futures. Ce choix relève de sa politique de sécurité et ne constitue pas un intervalle obligatoire du protocole.

Modèle de menace à long terme : compromission d'une clé et risque lié à Shor

Objectif de sécurité SG-1 — Insuffisance d'une seule clé : la récupération d'une clé privée ECDSA du participant, notamment la clé EVM opérationnelle, ne doit pas suffire à remplir la condition complète autorisant le transfert des fonds séquestrés vers une adresse contrôlée par l'attaquant. Il s'agit d'une propriété visée par la conception, non d'un constat sur l'implémentation ni d'un résultat vérifié indépendamment.

Scénario prospectif lié à Shor

L'algorithme de Shor et ses adaptations aux courbes elliptiques rendent le logarithme discret soluble en temps polynomial sur un ordinateur quantique idéal suffisamment puissant. Le protocole ne modifie pas ce fait. Il envisage plutôt qu'un attaquant futur récupère la clé privée opérationnelle correspondant à une clé publique exposée par l'activité normale de signature, puis examine ce que cette clé lui permet réellement de faire.

Objectif de l'attaquant

L'objectif économique pertinent de l'attaquant ne se limite pas à usurper la signature : il consiste à provoquer le transfert des fonds légitimes du participant vers une adresse qu'il contrôle. La version 4.3 sépare ces deux capacités.

La compromission de 0xSIGNER ne donne pas le contrôle de 0xRELEASE.

Pourquoi la clé récupérée reste insuffisante

La récupération de la clé EVM opérationnelle ne donne aucun accès connu à la clé Sei générée indépendamment, ne crée pas d'état canonique Sei authentique, ne satisfait pas le vérificateur indépendant et

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

ne révèle ni ne contrôle la clé privée de l'adresse froide indépendante. Si le bénéficiaire est immuable ou soumis à un engagement fort, l'attaquant ne peut simplement remplacer la destination par 0xATTACKER.

Surface d'attaque résiduelle

L'attaquant doit alors compromettre ou contourner d'autres frontières de confiance : second domaine d'autorisation, intégrité du registre, vérification de l'état canonique, contrôle du vérificateur, gouvernance des mises à niveau ou lien avec le bénéficiaire. Ces risques résiduels restent explicites.

Osnias-ID, intégrité des registres et protection contre le rejeu

Osnias-ID relie les domaines de sécurité du participant à l'état de son cycle de vie. Il n'apporte pas, en lui-même, de résistance cryptographique. L'intégrité des registres est donc une frontière de sécurité : les associations doivent être authentiques, cohérentes quant à leur version et bloquer l'opération en cas de divergence.

Cohérence des registres et risque TOCTOU

Si une association Osnias-ID change entre la création de l'autorisation et la libération sur EVM, il existe un risque de divergence entre le moment du contrôle et celui de l'utilisation (TOCTOU). La logique de production devrait lier l'autorisation à une version du registre, à un engagement immuable sur le bénéficiaire ou à un état de résolution propre au séquestre. Toute divergence entre vues des registres doit bloquer l'opération.

Séparation du plan de contrôle

La gestion des mises à niveau, des urgences et des registres ne doit pas rétablir un pouvoir de libération fondé sur une seule clé. En particulier, le signataire opérationnel ne doit pas pouvoir modifier seul l'adresse froide ni désactiver l'exigence du second domaine.

Frontière de confiance du vérificateur. Le vérificateur entre chaînes constitue une frontière de sécurité explicite. L'implémentation doit définir l'authentification de l'état canonique Sei, la politique de finalité et de réorganisation acceptée, le mécanisme de rotation ou de remplacement du vérificateur et le quorum ou la condition de preuve exigés avant toute libération EVM. Tant que ces éléments ne sont pas démontrés dans le code et les tests, SEC-003 reste OUVERT.

WW=00 : mode de sécurité du séquestre autonome

La même architecture peut fonctionner sans compensation. WW=00 peut être réservé à un mode explicite limité au séquestre : aucune chambre, aucun cycle de 7, 28 ou 91 jours, aucune compensation multilatérale et aucune transition d'état propre au clearing. Osnias-ID relie alors le séquestre EVM, le domaine d'autorisation indépendant et l'adresse de réception prédéfinie.

WW=00 signifie « aucun cycle de clearing / mode séquestre uniquement ». Il ne doit jamais être interprété comme un cycle de clearing de zéro semaine.

Dans ce mode, l'événement du second domaine peut prendre la forme d'une autorisation de libération, d'une transition d'état reflétée, d'un accord de politique ou d'un autre événement lié de façon unique et accepté par le vérificateur. L'objectif d'insuffisance d'une seule clé demeure.

Hygiène cryptographique, renouvellement de l'identité et sortie

Osnias permet le renouvellement complet et volontaire de l'identité cryptographique du participant comme mesure de sécurité opérationnelle et d'hygiène cryptographique. Le protocole n'impose aucun délai de renouvellement. Le participant choisit selon sa politique de sécurité, sa gouvernance, ses dispositifs de conservation et son analyse des risques.

Le participant peut choisir un renouvellement annuel, bisannuel, quinquennal, déclenché par un événement ou selon un autre rythme. Ces choix ne définissent aucune durée de validité imposée par le protocole aux clés ECDSA ou secp256k1.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

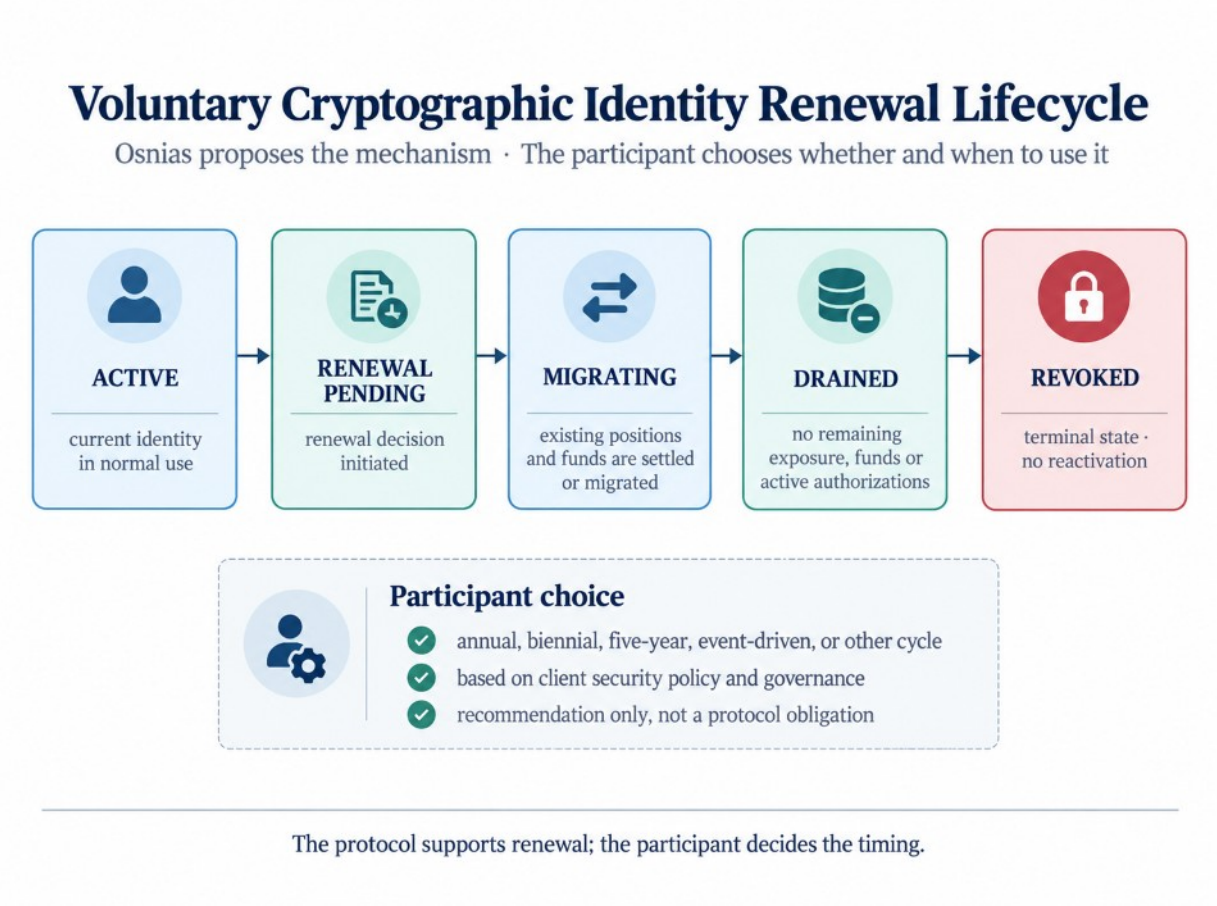


Figure 2 — Cycle de renouvellement volontaire de l'identité 10

Renouvellement complet

Un renouvellement complet crée une véritable nouvelle identité de sécurité, au lieu de modifier sur place une association de clés. Il peut comporter un nouvel Osnias-ID, de nouvelles graines indépendantes pour le signataire EVM, Sei et l'adresse froide, de nouvelles adresses sur chaîne, de nouvelles associations dans les registres et une migration ou un règlement contrôlé des positions et fonds existants.

Frontière de risque de la migration. La migration est un état du cycle de vie présentant un risque accru. L'association avec le successeur ne devrait devenir effective qu'après vérification de l'autorisation de migration, de la version du registre, des engagements sur les destinations et des positions restantes. À la fin de la transition contrôlée, l'ancienne identité ne doit plus pouvoir porter de nouvelles expositions.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

Sortie et révocation définitive

L'ancienne identité reste consultable à des fins de vérification historique et d'audit, mais perd toute capacité de créer de nouvelles autorisations après sa révocation finale. Un cycle possible est ACTIF → RENOUVELLEMENT EN ATTENTE → MIGRATION → SOLDÉ → RÉVOQUÉ. L'état RÉVOQUÉ est définitif et irréversible.

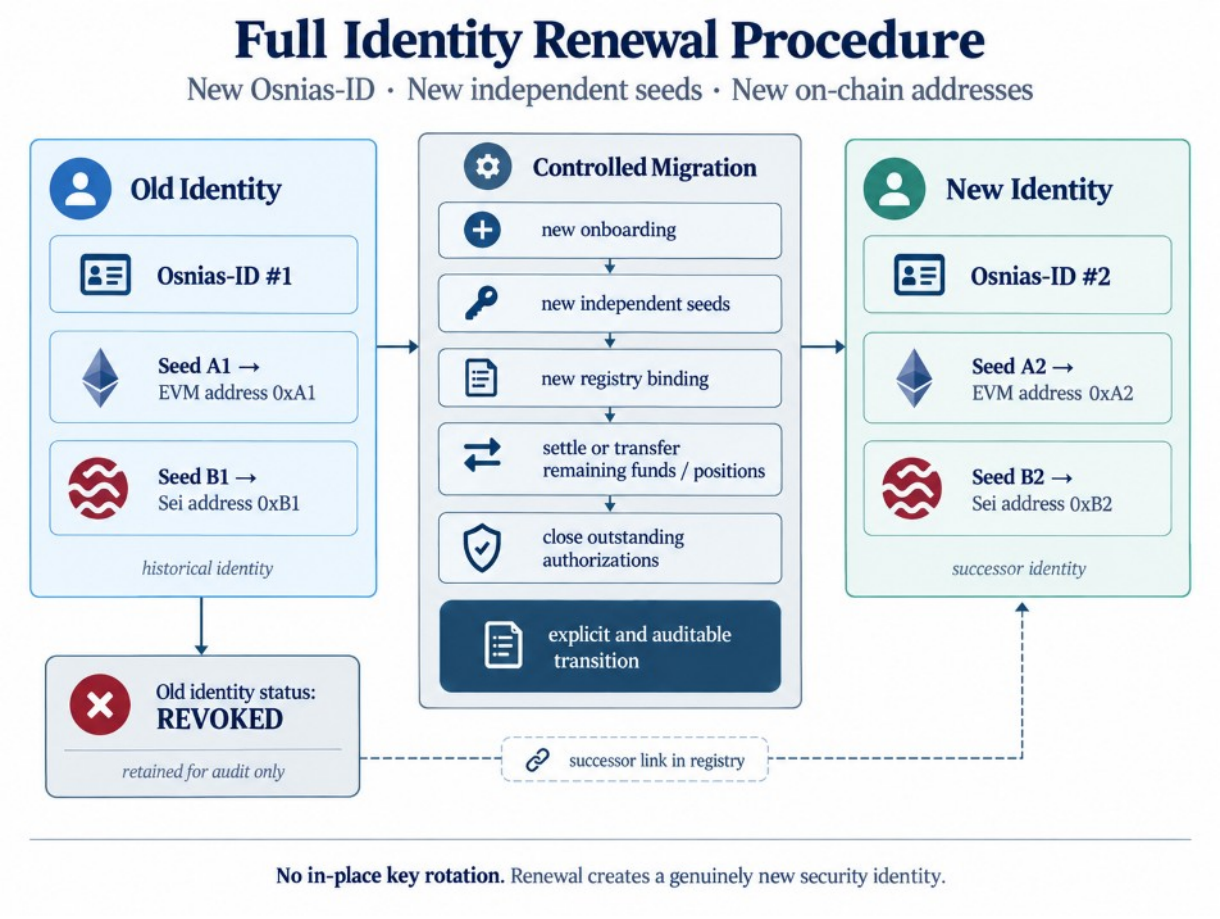


Figure 3 — Procédure de renouvellement complet de l'identité 11

Le registre peut, si nécessaire, conserver une référence permanente entre l'Osnias-ID révoqué et son successeur, sans modifier les associations historiques des clés de l'ancienne identité.

Ajustement du séquestre par le participant

Après le règlement du lundi, jour 1 du cycle, le participant dispose d'une fenêtre d'ajustement de son séquestre les mardi, mercredi et jeudi, soit les jours 2, 3 et 4. Pendant cette fenêtre, il peut ajouter des fonds ou demander le retrait du montant libérable de son séquestre, sous réserve des contrôles de sécurité, des positions restant à régler et du plafond applicable au nœud. Cette capacité appartient au participant et se distingue des pouvoirs du gestionnaire de nœud pendant le règlement du lundi.

Les retraits sont exécutés exclusivement vers l'adresse dédiée au retrait, préalablement enregistrée et distincte de l'adresse du séquestre. Cette destination correspond à l'adresse froide de réception du domaine C décrite dans le présent Livre. Une demande de retrait ne doit pas permettre de choisir une autre destination ; elle reste soumise à la condition composite de libération, à la vérification du montant libérable et aux protections contre le rejeu.

Le jeudi, jour 4, le séquestre est bloqué à la clôture de la fenêtre d'ajustement. Le montant retenu est alors immobilisé pour la phase active du cycle ; les ajouts et retraits à l'initiative du participant sont fermés jusqu'à la prochaine fenêtre autorisée. Cette immobilisation est distincte du gel des positions de clearing en fin de cycle. Le blocage ne doit pas empêcher les opérations de règlement autorisées pour le gestionnaire de nœud.

Référence de calendrier : Livre 4 — Cycles / Calendrier. La séquence lundi de règlement, mardi à jeudi d'ajustement puis blocage à la clôture du jeudi doit être portée par l'état canonique du cycle et appliquée par

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

les contrats. L'heure exacte de clôture UTC du jeudi et son traitement aux bornes restent à préciser dans le calendrier de référence ; aucune heure n'est présumée ici. Le calendrier testnet 1W doit être aligné explicitement avant de lui appliquer cette même séquence.

Clés de gestion et séparation des pouvoirs

Deux rôles de gestion complètent les trois domaines de sécurité A, B et C des participants. Chaque gestionnaire dispose d'une clé dédiée issue d'une graine indépendante : une graine propre au gestionnaire de chaque nœud et une graine distincte pour le gestionnaire Osnias. Il ne s'agit pas de deux clés supplémentaires à fournir par chaque participant. Aucune racine de dérivation ni donnée de récupération ne doit être partagée avec les domaines A, B et C ou entre les rôles de gestion.

Gestionnaire de nœud et fenêtre de netting

La clé du gestionnaire de nœud autorise les opérations de gestion sur le seul nœud auquel elle est affectée. Pendant la fenêtre de netting du premier lundi du cycle, ce gestionnaire a la main pour exécuter, dans les contrats intelligents, l'équilibrage des comptes de ses membres conformément aux positions nettes arrêtées pour le cycle clôturé. Ce lundi est le premier jour du cycle suivant ; l'équilibrage porte sur les obligations du cycle précédent.

Le gestionnaire procède à l'équilibrage interne des comptes de ses membres et à la prise en compte du solde net du nœud. Si son nœud doit un montant net au réseau, il organise le transfert du surplus dû depuis les séquestres concernés vers le compte du nœud, puis son règlement selon le circuit prévu. Si son nœud est créditeur, il attend la réception du solde net créditeur sur le compte du nœud avant de finaliser les ajustements correspondants dans les contrats des membres.

Exigences de conception. Les contrats doivent borner ces opérations au nœud, aux membres, au cycle et aux montants issus du netting. Le compte du nœud et les destinations de règlement doivent être identifiés dans les registres ; la clé de gestion ne doit pas permettre de désigner librement un bénéficiaire, de modifier les positions arrêtées ou d'utiliser les fonds d'un autre nœud. Les opérations doivent être traçables et protégées contre les doubles exécutions. La fenêtre autorisée doit être contrôlée par l'état canonique du cycle, et non par la seule horloge de l'interface.

Gestionnaire Osnias et paramètres des nœuds

La clé du gestionnaire Osnias est distincte des clés des gestionnaires de nœuds. Elle autorise l'administration des paramètres des nœuds, notamment l'affectation de leurs numéros et la configuration d'un seuil maximal de séquestre par nœud selon les demandes du régulateur applicables au nœud concerné. Elle ne confère pas, par ce seul rôle, le pouvoir d'exécuter le netting des membres à la place du gestionnaire de nœud ou de disposer des actifs séquestrés.

Le plafond de séquestre constitue une exigence de contrôle à implémenter dans les contrats. Sa définition doit préciser l'actif ou l'unité de compte, le périmètre d'agrégation des séquestres du nœud et les opérations susceptibles de dépasser le seuil. Une modification doit être datée, versionnée et journalisée avec sa référence de décision. Les modalités de réduction du plafond en présence de fonds déjà séquestrés restent à spécifier : une baisse ne doit ni libérer automatiquement les fonds ni empêcher le règlement des obligations existantes.

Conservation des clés et preuves de contrôle

Chaque gestionnaire conserve sa propre graine, sa clé privée et ses données de récupération sous sa responsabilité. La documentation doit préciser, pour chacun des deux rôles, les adresses autorisées, la chaîne et les contrats concernés, la procédure d'affectation, de rotation et de révocation, les mesures en cas de compromission et les éventuels contrôles à seuil. Les rôles de gestion restent soumis à l'invariant administratif : aucune clé seule ne doit contourner la condition composite de libération des fonds d'un participant ni modifier unilatéralement son bénéficiaire froid.

Les opérations de règlement du netting et les libérations vers le bénéficiaire froid constituent deux circuits distincts à documenter et à tester. Les transferts de netting doivent être justifiés par les positions arrêtées et limités aux destinations de règlement enregistrées. La description d'un rôle et de sa graine ne démontre pas

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

l'implémentation de ces restrictions. Les contrôles ci-dessus ont le statut EXIGENCE DE CONCEPTION / IMPLÉMENTATION ET TESTS EN ATTENTE.

Exigences de renforcement institutionnel

La séparation prévue par l'architecture doit être préservée par les contrôles opérationnels en production. Pour un déploiement institutionnel, les contrôles suivants font partie du modèle de sécurité :

- domaines de génération des clés indépendants et cérémonies vérifiables, de préférence avec des domaines HSM ou de conservation séparés ;
- rôles d'opérateurs, sauvegardes et voies de récupération distincts, avec analyse explicite des défaillances communes ;
- contrôle à seuil ou multipartite des registres, de l'administration du vérificateur et des mesures d'urgence ;
- procédures définies de rotation des clés, révocation, réaction aux incidents et blocage en cas d'incertitude ;
- mises à niveau immuables ou fortement encadrées, avec séparation explicite des fonctions ;
- aucune autorité unique de mise à niveau ne doit pouvoir modifier seule la condition de libération ou son bénéficiaire ;
- journalisation et surveillance continues des états des registres, oracles, vérificateurs et séquestres ;
- agilité cryptographique permettant aux clés, registres et vérificateurs de migrer vers des signatures post-quantiques normalisées ou hybrides sans changer la fonction d'Osnias-ID.

Des HSM distincts ou des procédures approuvées de génération aléatoire constituent des indices opérationnels de séparation des domaines de clés ; ils ne prouvent pas mathématiquement l'indépendance du système entier. Des administrateurs, sauvegardes, données de récupération ou plans de contrôle fournisseurs communs peuvent encore créer des défaillances communes.

Limites et travaux ouverts

Ce document ne prétend pas apporter une preuve formelle de la composition des contrôles. Avant toute affirmation de sécurité en production, l'implémentation doit préciser le modèle d'adversaire et de corruption, la vérification de l'état canonique, la cohérence des registres, le quorum du vérificateur et les pouvoirs de mise à niveau, la modification du bénéficiaire, la rotation des clés, les procédures d'urgence, les permissions et les circuits de règlement du gestionnaire de nœud, les paramètres et plafonds administrés par le gestionnaire Osnias, et une stratégie de migration post-quantique.

Le résultat doit être compris comme une défense en profondeur : elle peut accroître le coût et les préconditions d'une attaque, mais ne transforme pas ECDSA classique en signature post-quantique. Les signatures post-quantiques normalisées répondent au problème cryptographique de base ; Osnias traite la question de savoir si la compromission d'une seule clé opérationnelle devrait suffire à libérer ou détourner les fonds.

Feuille de route de l'implémentation et de la validation de sécurité

Cette évaluation décrit l'architecture de sécurité envisagée pour les utilisateurs finaux d'Osnias Clearing, son modèle de menace, ses frontières de confiance, les objectifs d'audit et les propriétés de sécurité visées. Elle sépare les contrôles de conception des preuves que devront produire l'implémentation et la validation.

Elle n'affirme pas que ces propriétés ont déjà été démontrées par du code de production déployé, une infrastructure auditée indépendamment ou un environnement opérationnel certifié.

L'étape suivante est l'implémentation de cette architecture sur le testnet public d'Osnias, notamment de la condition composite de libération, des associations des registres, des domaines d'autorisation indépendants, de l'adresse froide prédéfinie, de la protection contre le rejeu, des contrôles du cycle de vie et du blocage en cas d'incertitude.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

Une fois le système implémenté, une campagne de sécurité adversariale dédiée combinera analyse statique, tests d'intégration et scénarios d'attaque contrôlés contre le système réel.

La validation devrait comprendre, selon les besoins : l'analyse statique des contrats déployés, notamment avec Slither ; des tests adversariaux du circuit de libération et du lien avec le bénéficiaire ; des essais de rejeu, de substitution et d'état périmé ; des tests de cohérence des registres et des états du cycle de vie ; des scénarios de défaillance du vérificateur et des domaines d'autorisation ; des abus des mises à niveau et du plan de contrôle ; des essais de blocage en cas d'état incohérent ou indisponible ; des essais des droits des gestionnaires, des restrictions de netting et des plafonds de séquestre par nœud ; enfin la correction des constats et de nouveaux tests.

La méthode d'attaque détaillée sera définie à partir du système effectivement implémenté plutôt qu'arrêtée uniquement au stade de la conception.

À l'issue de la campagne, Osnias prévoit de publier un rapport distinct de validation de sécurité et d'implémentation.

Ce rapport devrait préciser l'implémentation réellement testée : versions des contrats, références des déploiements, conditions d'essai, scénarios d'attaque exécutés, résultats de l'analyse statique, défaillances observées, corrections, résultats des nouveaux tests et risques résiduels.

Cette évaluation de préparation à l'audit et le futur rapport de validation et d'implémentation répondent à des objectifs différents : le présent texte définit la conception, les objectifs de contrôle, les points ouverts et les preuves requises ; le futur rapport décrira le comportement observé après analyse statique, tests adversariaux, corrections et nouveaux tests.

Aucun succès d'implémentation ni résultat de sécurité favorable n'est présumé à ce stade.

Conclusion

Conclusion de l'évaluation. L'architecture examinée définit une séparation réelle entre le signataire EVM opérationnel, le domaine d'autorisation Sei indépendant et le bénéficiaire froid prédéfini. L'objectif principal est précis et testable : la compromission d'une clé ECDSA opérationnelle ne devrait pas, à elle seule, satisfaire toutes les conditions de libération ni rediriger les fonds séquestrés vers une adresse contrôlée par l'attaquant.

Au stade actuel du document, il s'agit d'une propriété de sécurité visée et d'un objectif de conception, non d'un résultat constaté sur l'implémentation ou vérifié indépendamment. L'implémentation des contrats, l'authentification de l'état canonique, la gouvernance du vérificateur, les contrôles administratifs, les tests adversariaux, les corrections et de nouveaux tests restent nécessaires avant de considérer les contrôles comme vérifiés.

Ce document sert à préparer l'audit et la revue technique. Il ne constitue ni un audit indépendant, ni une vérification formelle, ni un rapport de test d'intrusion, ni une certification ou qualification de sécurité en production.

Conçu pour les chaînes actuelles. La sécurité anticipe le risque suivant.

Bibliographie

[1] P. W. Shor, "Polynomial-time algorithms for prime factorization and discrete logarithms on a quantum computer," SIAM Journal on Computing, vol. 26, no. 5, 1997.

[2] J. Proos and C. Zalka, "Shor's discrete logarithm quantum algorithm for elliptic curves," Quantum Information & Computation, vol. 3, no. 4, 2003. arXiv: quant-ph/0301141.

[3] M. Roetteler, M. Naehrig, K. M. Svore, and K. Lauter, "Quantum resource estimates for computing elliptic curve discrete logarithms," ASIACRYPT 2017, LNCS 10625.

[4] D. Johnson, A. Menezes, and S. Vanstone, "The elliptic curve digital signature algorithm (ECDSA)," International Journal of Information Security, 2001.

[5] SECG, SEC 2: Recommended Elliptic Curve Domain Parameters, Version 2.0, 2010.

[6] NIST, Module-Lattice-Based Digital Signature Standard, FIPS 204, 2024.

[7] NIST, Stateless Hash-Based Digital Signature Standard, FIPS 205, 2024.

[8] NIST SP 800-90A Rev. 1 and SP 800-90B, random bit generation and entropy-source recommendations.

[9] P. Wuille, BIP-32: Hierarchical Deterministic Wallets, 2012.

[10] G. Wood, Ethereum: A Secure Decentralised Generalised Transaction Ledger (Ethereum Yellow Paper).

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.

[11] Sei Labs, Sei technical documentation, consensus and EVM documentation.

[12] D. Bouzon, “Osnias-ID: An internal interchain identifier for multi-chain clearing,” Osnias Clearing Technical Report, Release 2.0, 2026.

[13] ISO 19011:2026, Guidelines for auditing management systems, Edition 4, May 2026.

[14] ISO/IEC 27001:2022, Information security, cybersecurity and privacy protection — Information security management systems — Requirements.

[15] ISO/IEC 27002:2022, Information security, cybersecurity and privacy protection — Information security controls.

[16] ISO/IEC 27005:2022, Information security, cybersecurity and privacy protection — Guidance on managing information security risks.

[17] ISO/IEC 27034-1:2011, Information technology — Security techniques — Application security — Part 1: Overview and concepts (confirmed current by ISO review).

[18] NIST Special Publication 800-218, Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities, 2022.

Précision sur les normes : les références [13] à [18] sont citées comme guides méthodologiques et de conception. Elles n’impliquent aucune certification, évaluation de conformité, approbation ni validation indépendante d’Osnias Clearing.

© 2026 Denis Bouzon — Osnias Clearing · Sous licence CC BY 4.0.